

**UNIVERSIDADE DE MOGI DAS CRUZES**  
**SISTEMAS DE INFORMAÇÃO**

**CASSIANO JESUS SILVA - 11241104826**  
**GUILHERME DA SILVA BONIFÁCIO - 11241103208**  
**YAN BAUMGARTEN COSTA - 11241100266**

**HEALTH IN SIGHT**  
**Website Informativo sobre Doenças**  
**Instrutor: Fabiano**

Mogi Das Cruzes, SP  
2026

## **RESUMO**

O presente projeto propõe o desenvolvimento de um sistema web voltado à divulgação de informações sobre doenças e suas respectivas formas de prevenção. A plataforma terá como objetivo facilitar o acesso da população a conteúdos de saúde de maneira simples, organizada e acessível, contribuindo para a disseminação de informações que possam auxiliar na adoção de hábitos preventivos e na busca por atendimento profissional quando necessário.

O sistema permitirá que os usuários consultem informações sobre diferentes doenças, organizadas por categorias, como doenças infecciosas, doenças crônicas e doenças relacionadas a hábitos de vida. Para cada doença, poderão ser disponibilizadas informações gerais, formas de transmissão, principais sintomas, fatores de risco e medidas de prevenção. A plataforma também contará com mecanismos de pesquisa e filtragem, facilitando a localização dos conteúdos desejados.

Além da área destinada aos usuários, o sistema contará com uma área administrativa responsável pelo gerenciamento das informações disponibilizadas. Administradores poderão cadastrar, editar, analisar e excluir conteúdo sobre doenças e categorias, garantindo maior organização e facilidade na manutenção da plataforma.

A proposta busca utilizar a tecnologia como ferramenta de apoio à educação e a conscientização em saúde, disponibilizando informações de forma clara e acessível. O sistema será desenvolvido em conformidade com a Lei Geral de Proteção de Dados Pessoais (LGPD), adotando medidas para garantir a privacidade, a segurança, e também o tratamento adequado dos dados pessoais dos usuários. Ressalta-se que a plataforma terá caráter exclusivamente informativo e educativo, não tendo como finalidade realizar diagnósticos ou substituir a avaliação de profissionais da área da saúde.

## SUMÁRIO

|                                                                 |    |
|-----------------------------------------------------------------|----|
| 1 INTRODUÇÃO.....                                               | 3  |
| 1.1 PÚBLICO-ALVO E CONTEXTO NA SAUDE .....                      | 3  |
| 1.2 ESCOPO DA SOLUÇÃO.....                                      | 3  |
| 1.2.2 QUAL O POSSIVEL NOME DA SOLUÇÃO TÉCNOLOGICA NA SAÚDE..... | 3  |
| 1.2.2 PROBLEMA DE PESQUISA.....                                 | 3  |
| 1.2.3 JUSTIFICATIVA DO PROJETO.....                             | 3  |
| 1.3 OBJETIVOS .....                                             | 4  |
| 1.3.1 OBJETIVO GERAL .....                                      | 4  |
| 1.3.2 OBJETIVO ESPECÍFICOS .....                                | 4  |
| 2 REFERENCIAL TEÓRICO .....                                     | 4  |
| 3 METODOLOGIA E ARQUITETURA.....                                | 5  |
| 3.1 METODOLOGIA DE DESENVOLVIMENTO.....                         | 5  |
| 3.2 LEVANTAMENTO DE REQUISITOS .....                            | 5  |
| 3.2.1 REQUISITOS FUNCIONAIS .....                               | 5  |
| 3.2.2 REQUISITOS NÃO FUNCIONAIS .....                           | 6  |
| 3.3 PERTINÊNCIA COM A LGPD NO CONTEXTO DA SAÚDE.....            | 7  |
| 3.4 DIAGRAMA DE ARQUITETURA DO SISTEMA .....                    | 8  |
| 3.5 MATRIZ DE RISCOS ATIVOS E AMEAÇAS.....                      | 8  |
| 3.6 TECNOLOGIAS E FERRAMENTAS UTILIZADAS.....                   | 8  |
| 3.7 ESCOPO DA SOLUÇÃO.....                                      | 8  |
| 3.7.1 O QUE FAZ PARTE DO ESCOPO (IN-SCOPE) .....                | 8  |
| 3.7.2 O QUE ESTÁ FORA DO ESCOPO (OUT-OF-SCOPE) .....            | 8  |
| 3.8 USUARIOS E PERFIS DE ACESSO.....                            | 9  |
| 3.9 MODELO E ENTIDADE-RELACIONAMENTO .....                      | 9  |
| 4 DESENVOLVIMENTO E IMPLEMENTAÇÃO .....                         | 10 |
| 4.1 ESTRUTURA DO PROJETO E CÓDIGO.....                          | 10 |
| 4.2 FUNCIONALIDADES E TELAS .....                               | 10 |
| 5 TESTES, VALIDAÇÃO E RESULTADOS .....                          | 10 |
| 5.1 ESTRATÉGIAS DE TESTES .....                                 | 10 |
| 5.2 RESULTADOS OBTIDOS .....                                    | 10 |

|                              |    |
|------------------------------|----|
| 6 CONSIDERAÇÕES FINAIS ..... | 10 |
| 6.1 CONCLUSÃO .....          | 10 |

# **1 INTRODUÇÃO**

## **1.1 PÚBLICO-ALVO E CONTEXTO NA SAUDE**

O sistema será destinado ao público em geral, especialmente pessoas que buscam informações básicas sobre doenças, seus sintomas, fatores de risco e formas de prevenção. A plataforma terá como objetivo disponibilizar informações de saúde de maneira simples, organizada e acessível, podendo ser utilizada por pessoas de diferentes faixas etárias e níveis de conhecimento sobre o assunto.

No contexto da saúde, muitas pessoas utilizam a internet para buscar informações sobre sintomas, doenças e formas de prevenção, porém podem encontrar conteúdos incorretos, incompletos ou de difícil compreensão. Nesse cenário, o sistema será desenvolvido como uma plataforma educativa, reunindo informações sobre diferentes doenças, seus principais sintomas, formas de transmissão, fatores de risco e medidas preventivas.

A plataforma terá caráter exclusivamente informativo e preventivo, não realizando diagnósticos ou indicando tratamentos. Dessa forma, busca contribuir para a educação em saúde, incentivar hábitos preventivos e conscientizar os usuários sobre a importância de buscar orientação de profissionais de saúde quando necessário. As informações disponibilizadas deverão ser baseadas em fontes confiáveis, contribuindo para que o usuário tenha acesso a conteúdo organizados e de fácil compreensão.

## **1.2 ESCOPO DA SOLUÇÃO**

### **1.2.2 QUAL O POSSIVEL NOME DA SOLUÇÃO TECNOLÓGICA NA SAÚDE**

O Health in Sight é uma solução tecnológica desenvolvida para disponibilizar informações sobre diferentes doenças, seus principais sintomas, fatores de risco e formas de prevenção. A plataforma tem como objetivo facilitar o acesso da população a informações de saúde de maneira simples, organizada e acessível, contribuindo para a conscientização e a educação em saúde. O sistema terá caráter exclusivamente informativo e preventivo, não realizando diagnósticos ou substituindo a avaliação de profissionais da área da saúde.

### **1.2.2 PROBLEMA DE PESQUISA**

Como disponibilizar informações confiáveis, organizadas e de fácil compreensão sobre doenças, seus principais sintomas, fatores de risco e formas de prevenção, contribuindo para a conscientização da população e para a adoção de medidas preventivas de saúde?

### **1.2.3 JUSTIFICATIVA DO PROJETO**

O desenvolvimento de um portal web para centralizar informações de saúde produzidas por órgãos oficiais e instituições parceiras justifica-se pela dificuldade que a população enfrenta ao buscar orientação confiável, uma vez que esse conteúdo está distribuído em diferentes portais e canais de comunicação, competindo em igualdade de condições com material sem procedência verificada.

A proposta busca reunir essas informações em um único ambiente, com curadoria, organização por tema e atribuição explícita de autoria, tornando a consulta mais simples e confiável. Dessa forma, o sistema contribui para a promoção da saúde, para a prevenção de doenças e para o enfrentamento da desinformação. Justifica-se igualmente sob a perspectiva da segurança da informação, uma vez que o domínio da saúde é um dos que exigem maior rigor no tratamento de dados pessoais, constituindo contexto adequado para a aplicação prática de controles de autenticação, criptografia, auditoria e conformidade normativa.

### **1.3 OBJETIVOS**

#### **1.3.1 OBJETIVO GERAL**

Desenvolver um portal web seguro para centralizar e divulgar conteúdos confiáveis sobre prevenção e tratamento de doenças, produzidos por órgãos oficiais e instituições parceiras, facilitando o acesso da população à informação de saúde verificada, sem coleta de dados pessoais sensíveis.

#### **1.3.2 OBJETIVO ESPECÍFICOS**

- a) Desenvolver um sistema de cadastro e autenticação dos usuários com autenticação em duas etapas;
- b) Organizar os conteúdos por condição de saúde, área, público-alvo e formato do material;
- c) Implementar uma ferramenta de pesquisa e filtros sobre o acervo;
- d) Conter os principais requisitos de segurança necessários para esse tipo de plataforma com base na LGPD;
- e) Assegurar a atribuição da fonte oficial de cada conteúdo publicado, com redirecionamento para o material original;
- f) Aplicar o princípio da minimização, restringindo a coleta de dados pessoais ao estritamente necessário para a autenticação.

## 2 REFERENCIAL TEÓRICO

A revisão de literatura que fundamenta este projeto articula três eixos técnicos — proteção de credenciais, autenticação multifator e integridade de registros de auditoria — além do enquadramento legal imposto pela LGPD.

No armazenamento de senhas, a literatura e as recomendações de mercado convergem para o uso de funções de derivação de chave com custo de memória e tempo ajustável, em substituição a funções de hash genéricas como SHA-256. O algoritmo Argon2id, padronizado na RFC 9106 (ALWEN et al., 2021), é a recomendação atual do OWASP Password Storage Cheat Sheet (OWASP FOUNDATION, 2023) por resistir tanto a ataques por dicionário paralelizados em GPU quanto a ataques por canal lateral, razão pela qual foi adotado neste projeto, com salt único por usuário.

A autenticação em duas etapas segue o padrão TOTP (Time-based One-Time Password), especificado na RFC 6238 (M'RAIHI et al., 2011), que deriva códigos numéricos de validade curta a partir de um segredo compartilhado e do relógio do sistema. O NIST SP 800-63B (NIST, 2017) recomenda esse fator adicional como mitigação eficaz contra o reuso de credenciais vazadas em outros serviços (credential stuffing).

A trilha de auditoria implementada segue o modelo de logs encadeados por hash proposto por Schneier e Kelsey (1999): cada evento incorpora criptograficamente o hash do evento anterior, de modo que qualquer alteração retroativa de um registro quebra a cadeia de verificação dos registros seguintes — propriedade central para a evidência de integridade exigida pelo item 5.3 do check-list do projeto.

Por fim, o tratamento de dados pessoais observa a Lei Geral de Proteção de Dados Pessoais (BRASIL, 2018), que classifica dados de saúde como sensíveis (art. 5º, II) e estabelece, no art. 6º, III, o princípio da necessidade como limite à coleta. A decisão de projeto de não coletar nenhum dado de saúde do usuário — apenas os dados cadastrais mínimos exigidos para a autenticação — decorre diretamente desse princípio.

## 3 METODOLOGIA E ARQUITETURA

### 3.1 METODOLOGIA DE DESENVOLVIMENTO

O desenvolvimento seguiu um processo incremental, organizado nos cinco blocos de requisitos definidos pelo check-list da disciplina: (1) autenticação e gestão de credenciais, (2) recuperação de senha, (3) criptografia e comunicação segura, (4) conformidade com a LGPD e (5) auditoria e logs. Cada bloco só foi considerado concluído após a implementação, a escrita dos testes automatizados correspondentes e a validação manual via front-end.

O controle de versão foi feito em Git, com repositório hospedado no GitHub e histórico de commits organizados por etapa de trabalho, permitindo rastrear a evolução de cada requisito.

A divisão de tarefas entre os três integrantes foi acompanhada por um quadro Kanban, com colunas para tarefas pendentes, em andamento e concluídas.

Em ambiente de desenvolvimento, a aplicação roda sobre SQLite; em produção, sobre MySQL gerenciado pela Aiven, com conexão TLS obrigatória. A suíte de testes automatizados (Django TestCase) roda sempre contra um banco de dados em memória, isolado do ambiente de produção, e é executada antes de cada commit relevante. O deploy é feito no Render a partir da branch principal do repositório.

## 3.2 LEVANTAMENTO DE REQUISITOS

### 3.2.1 REQUISITOS FUNCIONAIS

| RF     | DESCRIÇÃO                                                                                                                                                     |
|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [RF01] | <b>Autenticação em Duas Etapas:</b> O sistema deve permitir e exigir a validação via Autentificação de dois Fatores (2FA) após a primeira autenticação.       |
| [RF02] | <b>Encerramento de Sessão (Logout):</b> O sistema deve oferecer a opção de logout com invalidação imediata da sessão do usuário.                              |
| [RF03] | <b>Recuperação de Senha:</b> O sistema deve permitir que o usuário solicite a redefinição/recuperação de senha via e-mail ou código.                          |
| [RF04] | <b>Consentimento LGPD:</b> O sistema deve solicitar e registrar o consentimento explícito do usuário armazenando a data, versão e finalidade de uso de dados. |
| [RF05] | <b>Revogação e Consentimento:</b> O sistema deve oferecer interface para que o usuário revogue o consentimento concedido a qualquer momento.                  |
| [RF06] | <b>Consulta aos Dados do Titular:</b> O sistema deve permitir que o usuário consulte a listagem completa dos seus dados pessoais armazenados.                 |
| [RF07] | <b>Exportação de Dados:</b> O sistema deve oferecer funcionalidade para o usuário exportar seus dados pessoais em formato estruturado.                        |

|        |                                                                                                                                                   |
|--------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| [RF08] | <b>Exclusão de Dados (Direito ao Esquecimento):</b> O sistema deve permitir que o usuário solicite a exclusão definitiva dos seus dados pessoais. |
| [RF09] | <b>Registro de Logs de Autenticação:</b> O sistema deve registrar eventos de login, falhas de acesso e uso do 2FA.                                |

Fonte: Elaborado pelos autores.

### 3.2.2 REQUISITOS NÃO FUNCIONAIS

| RF      | DESCRIÇÃO                                                                                                                                                                                             |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [RNF01] | <b>Segurança:</b> As senhas devem ser armazenadas utilizando algoritmos de hash seguro, com salt criptográfico único por usuário e parâmetros de custo justificados.                                  |
| [RNF02] | <b>Segurança:</b> As sessões ativas dos usuários devem expirar automaticamente após o tempo limite de inatividade.                                                                                    |
| [RNF03] | <b>Segurança:</b> O sistema deve possuir mecanismos de proteção contra-ataques de força bruta (como rate limit, bloqueio temporário ou atraso).                                                       |
| [RNF04] | <b>Segurança:</b> Os tokens de recuperação de senha devem ser gerados de forma criptograficamente segura, possuir tempo de expiração curto e ser invalidados após o uso ou após o tempo de expiração. |
| [RNF05] | <b>Auditoria:</b> O sistema deve registrar em logs todas as solicitações de recuperação de senha, junto do resultado de sucesso ou falha do processo.                                                 |
| [RNF06] | <b>Comunicação:</b> Todo o tráfego de dados deve ser protegido obrigatoriamente via TLS/HTTPS, bloqueando conexões não seguras.                                                                       |

|         |                                                                                                                                                                     |
|---------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [RNF07] | <b>Criptografia:</b> Dados sensíveis no banco de dados devem ser criptografados em repouso com algoritmo adequado e chaves protegidas                               |
| [RNF08] | <b>LGPD/Privacidade:</b> A arquitetura da base de dados deve seguir o princípio da minimização, associando e limitando cada dado coletado a uma finalidade estrita. |
| [RNF09] | <b>Auditoria:</b> Os arquivos e registros de logs de auditoria devem ter proteção contra alteração, exclusão ou adulteração indevida.                               |

Fonte: Elaborado pelos autores.

### 3.3 PERTINÊNCIA COM A LGPD NO CONTEXTO DA SAÚDE

A Lei Geral de Proteção de Dados Pessoais, em seu artigo 5º, inciso II, classifica os dados referentes à saúde como dados pessoais sensíveis, submetendo-os ao regime mais restritivo do artigo 11. Diante desse risco, o projeto adota o princípio da necessidade, previsto no artigo 6º, inciso III: a plataforma não coleta qualquer dado de saúde de seus usuários, e o acervo de conteúdo é público e idêntico para todos os visitantes, sem personalização baseada em condição de saúde.

Os dados pessoais efetivamente tratados limitam-se aos necessários para a autenticação e para a segurança do próprio sistema: nome completo e endereço de e-mail para identificação e acesso; senha armazenada exclusivamente como hash criptográfico; segredo de autenticação em duas etapas, cifrado em repouso; endereço IP e data e hora dos eventos de autenticação, para rastreabilidade; e o registro de consentimento, com data, versão do termo e finalidade aceita.

Aceitação dos termos de uso da plataforma e da política de privacidade, com registro da versão aceita, e atendimento às requisições dos titulares que solicitarem a consulta, a exportação, a correção ou a exclusão dos seus dados, bem como a revogação do consentimento a qualquer momento, conforme o artigo 18 da referida lei.

Medidas de segurança aptas a proteger dados pessoais de acesso não autorizado, prevenindo e limitando o acesso conforme a função de cada colaborador, praticando auditorias para fins de rastreabilidade dos logs de acesso. Os registros de auditoria são preservados de forma pseudonimizada após a exclusão da conta, com fundamento no artigo 16, incisos I e III.

### 3.4 DIAGRAMA DE ARQUITETURA DO SISTEMA

O sistema segue uma arquitetura monolítica: uma única aplicação Django, hospedada no

Render, concentra a camada de apresentação (templates), a lógica de negócio e o acesso a dados, comunicando-se com um banco de dados MySQL gerenciado pela Aiven exclusivamente por conexão cifrada (TLS). Não há camadas adicionais como API Gateway, filas de mensagens ou um serviço de gerenciamento de chaves dedicado (KMS): as responsabilidades de segurança — hashing de senha, validação do segundo fator, bloqueio por força bruta e geração da trilha de auditoria — são implementadas como módulos e middlewares internos da própria aplicação Django, conforme ilustrado na figura a seguir.

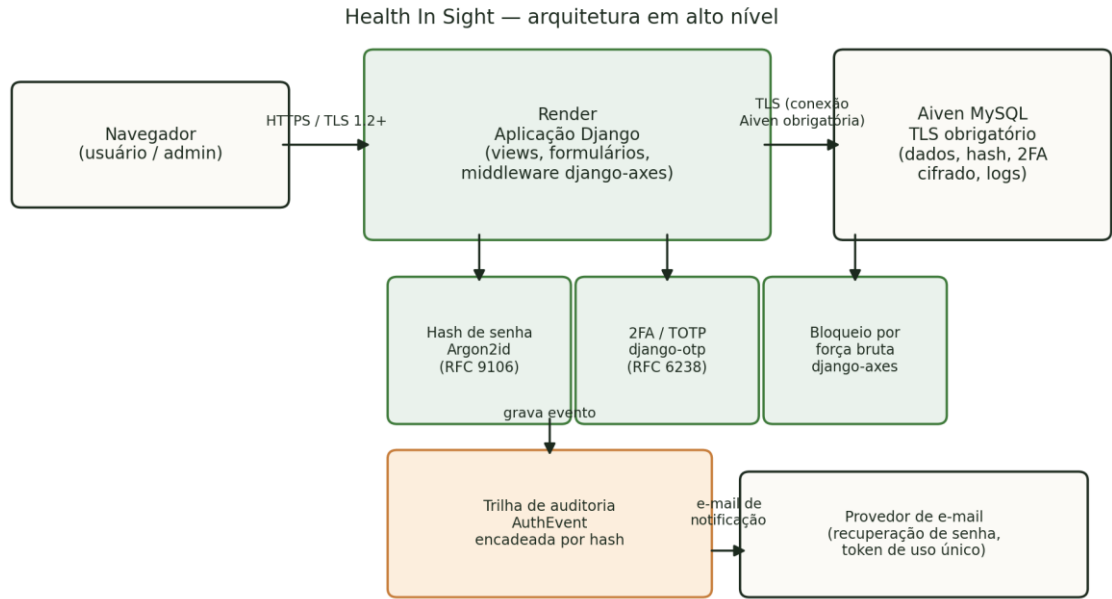


Figura 1 — Arquitetura em alto nível do Health In Sight.

### 3.5 MATRIZ DE RISCOS ATIVOS E AMEAÇAS

Os principais ativos protegidos pelo sistema são: o banco de dados de usuários (Aiven MySQL), o hash das senhas (Argon2id), o segredo do segundo fator (TOTP), a SECRET\_KEY da aplicação Django, a sessão autenticada do usuário e a própria trilha de auditoria. A tabela a seguir aplica o modelo STRIDE a esses ativos, associando cada ameaça identificada à contramedida efetivamente implementada no sistema entregue — e não a controles genéricos de mercado.

| Categoria STRIDE | Ameaça identificada                                          | Ativo afetado       | Contramedida implementada                                                                          |
|------------------|--------------------------------------------------------------|---------------------|----------------------------------------------------------------------------------------------------|
| Spoofing         | Preenchimento de credenciais vazadas ou força bruta no login | Conta do usuário    | django-axes: bloqueio após 5 tentativas, combinando conta e endereço IP (AXES_LOCKOUT_PARAMETERS). |
| Tampering        | Alteração retroativa de                                      | Trilha de auditoria | Encadeamento por hash: cada evento grava o hash do evento anterior;                                |

|                               |                                                                                |                                                 |                                                                                                                                                                                   |
|-------------------------------|--------------------------------------------------------------------------------|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                               | um registro da trilha de auditoria                                             |                                                 | qualquer alteração quebra a cadeia, detectável pelo comando <code>verificar_logs</code> .                                                                                         |
| <b>Repudiation</b>            | Usuário negar ter realizado login, tentativa de acesso ou exclusão de conta    | Trilha de auditoria                             | Registro de IP de origem, data/hora e tipo de evento para cada evento de autenticação, capturado via signals do Django — inclusive eventos disparados pelo painel administrativo. |
| <b>Information Disclosure</b> | Extração do banco de dados expondo senhas ou segredos de 2FA                   | Hash de senha, segredo TOTP                     | Senha armazenada apenas como hash Argon2id (irreversível); segredo do TOTP cifrado em repouso.                                                                                    |
| <b>Denial of Service</b>      | Sobrecarga do endpoint de login com tentativas repetidas                       | Disponibilidade do serviço de autenticação      | O mesmo mecanismo de bloqueio do django-axes limita a taxa efetiva de tentativas por conta e por IP.                                                                              |
| <b>Elevation of Privilege</b> | Usuário comum tentando acessar rotas administrativas ou dados de outro titular | Painel administrativo, dados de outros usuários | Checagem de permissão de administrador em toda view administrativa; nenhum perfil tem permissão para alterar ou excluir registros da trilha de auditoria.                         |

Fonte: Elaborado pelos autores.

### 3.6 TECNOLOGIAS E FERRAMENTAS UTILIZADAS

Para a execução deste projeto foi necessário um conjunto de ferramentas e tecnologias. A seguir estão as linguagens de programação e ferramentas utilizadas no desenvolvimento do projeto:

- a) HTML5;
- b) CSS3;
- c) JAVASCRIPT;
- d) PYTHON;
- e) MYSQL.

### 3.7 ESCOPO DA SOLUÇÃO

#### 3.7.1 O QUE FAZ PARTE DO ESCOPO (IN-SCOPE)

O escopo do projeto contempla as seguintes funcionalidades:

- a) Cadastro e login dos administradores com autenticação em duas etapas;
- b) Busca e filtros por condição de saúde, área, público-alvo e formato do material;

- c) Registro dos eventos de autenticação em trilha de auditoria protegida contra alteração;
- d) Criação de janela para a exibição do conteúdo;
- e) Segurança com Hash e Criptografia;
- f) Sessões com tempo de expiração.

### **3.7.2 O QUE ESTÁ FORA DO ESCOPO (OUT-OF-SCOPE)**

Não fazem parte do escopo deste projeto:

- a) Diagnóstico, triagem de sintomas ou qualquer orientação clínica individualizada;
- b) Prescrição de medicamentos ou de tratamentos;
- c) Teleconsulta, agendamento de consultas e atendimento por profissionais de saúde;
- d) Prontuário eletrônico, armazenamento de exames, laudos ou histórico clínico;
- e) Coleta de qualquer dado de saúde do usuário, incluindo condições, sintomas e medicamentos em uso;
- f) Produção própria de conteúdo médico, cabendo à plataforma apenas a curadoria e a divulgação de material de fontes oficiais;
- g) Comercialização de medicamentos, produtos ou serviços de saúde;
- h) Integração com sistemas de saúde públicos ou privados, tais como prontuários hospitalares ou bases de operadoras.

### **3.8 USUARIOS E PERFIS DE ACESSO**

Os perfis de usuários que vão interagir com o sistema são o visitante, o usuário cadastrado, os administradores de TI e o encarregado pelo tratamento de dados pessoais.

#### **Permissões:**

Usuario: Consulta ao acervo público de conteúdos, sem necessidade de inserção de dados;

Administradores de TI: Criação, alteração, análise e exclusão de conteúdos na plataforma, gestão da infraestrutura, validação e configurações de rastreamento de URLs, manutenção das chaves criptográficas, direito para analisar o registro de auditoria e acesso ao banco de dados.

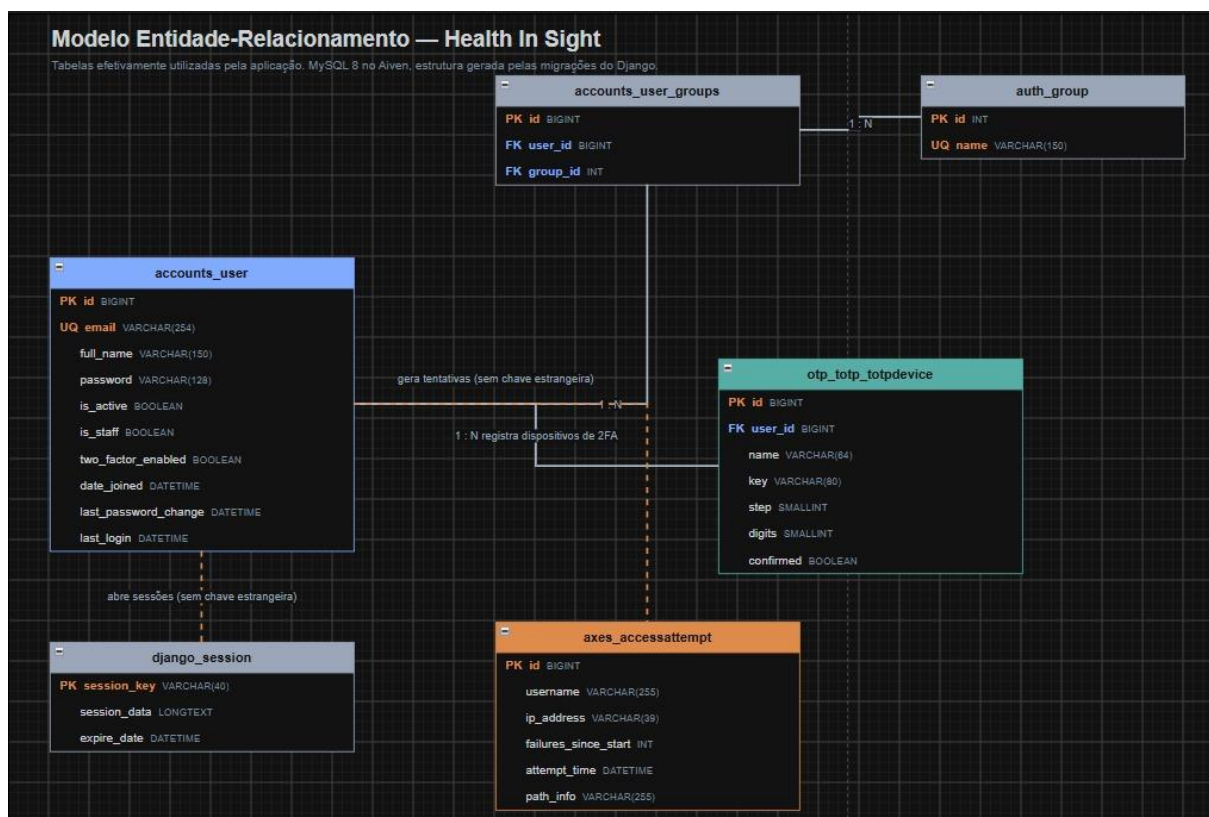
## Restrição de acesso:

Usuários: Não é permitido manipular conteúdo, configurações ou dados de terceiros, permitido somente a leitura do Website.

Nenhum perfil possui permissão para alterar ou excluir registros da trilha de auditoria.

Administradores de TI: Não é permitido excluir o próprio perfil caso seja o único no sistema.

## 3.9 MODELO E ENTIDADE-RELACIONAMENTO



Observação para revisão da equipe: o diagrama acima cobre as entidades Administrador e Card (conteúdo). Como as seções 3.3 e 3.5 descrevem também o consentimento LGPD, o segredo de 2FA e a trilha de auditoria como dados persistidos, vale conferir se essas entidades já existem como tabelas separadas no models.py atual e, se sim, incluí-las neste diagrama antes da entrega, para que o modelo represente o sistema completo.

## 4 DESENVOLVIMENTO E IMPLEMENTAÇÃO

### 4.1 ESTRUTURA DO PROJETO E CÓDIGO

O projeto é organizado em aplicações Django separadas por responsabilidade — por exemplo, uma app para contas e autenticação de usuários, uma app para o acervo de conteúdos de saúde

A configuração da aplicação é orientada por variáveis de ambiente: quando a variável `DB_HOST` não está definida, a aplicação cai automaticamente para SQLite (usado em desenvolvimento e nos testes automatizados); quando definida, conecta-se ao MySQL da Aiven com TLS obrigatório, usado em produção.

## 4.2 FUNCIONALIDADES E TELAS

### 4.2.1 TELA HOME



*Legenda: Tela inicial, sem necessidade de login para o usuário comum: título de posicionamento e reforço de que o conteúdo não substitui a avaliação de um profissional de saúde contendo as informações do site.*

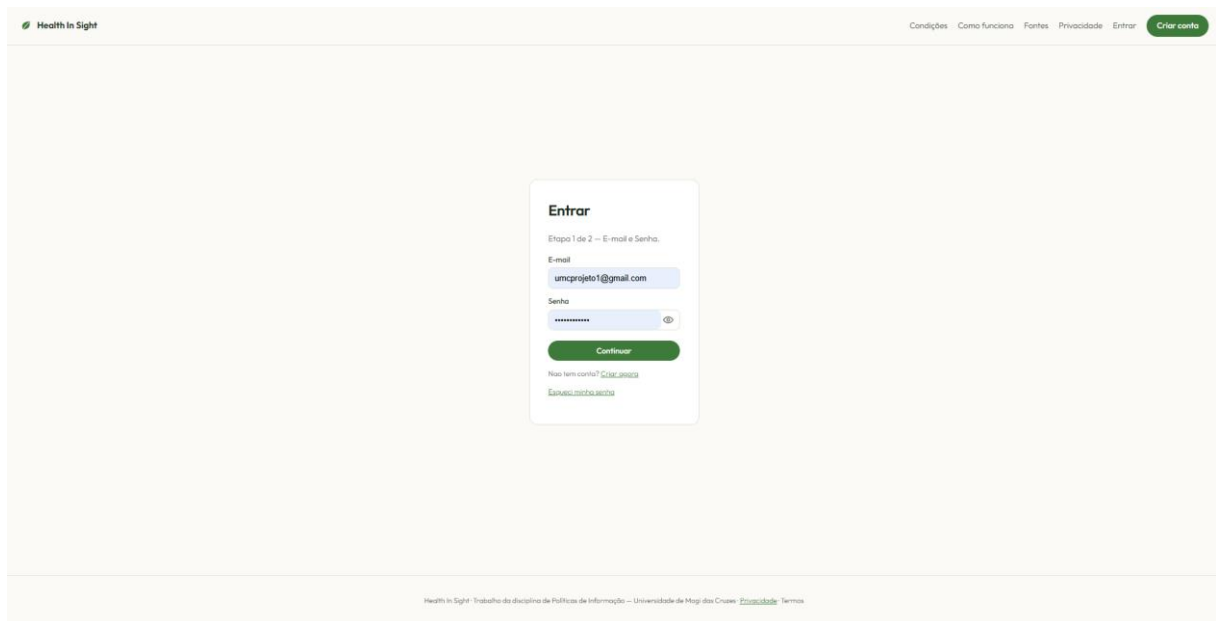
#### 4.2.2 TELA CRIAÇÃO DE CONTA

The top screenshot shows a mobile interface for 'Health In Sight'. A central pop-up titled 'Como cuidamos dos seus dados de saúde' (How we care for your health data) is displayed. It contains four numbered points: 1. Data collection (Name, email, password, CPF, phone, address, birth date); 2. Clinical-informative use only; 3. Password security (Argon2id hash, AES-256-GCM encryption, HTTPS); 4. User rights (access, export, revoke, delete). Below the points is a link to the full privacy policy and a checkbox for agreement. 'Agora não' and 'Concordar e Continuar' buttons are at the bottom.

The bottom screenshot shows the desktop version of the 'Criar conta' (Create account) form. It includes fields for 'E-mail', 'Nome completo', and 'Senha' (with password requirements: not too similar to personal info, at least 10 characters, not commonly used, not purely numeric). A 'Confirmação de senha' field is also present. A checkbox for terms and conditions is checked. Links for the privacy policy and a 'Criar conta' button are at the bottom. A footer at the very bottom reads: 'Health In Sight - Trabalho da disciplina de Políticas de Informação - Universidade de Mogi das Cruzes | Privacidade | Termos'.

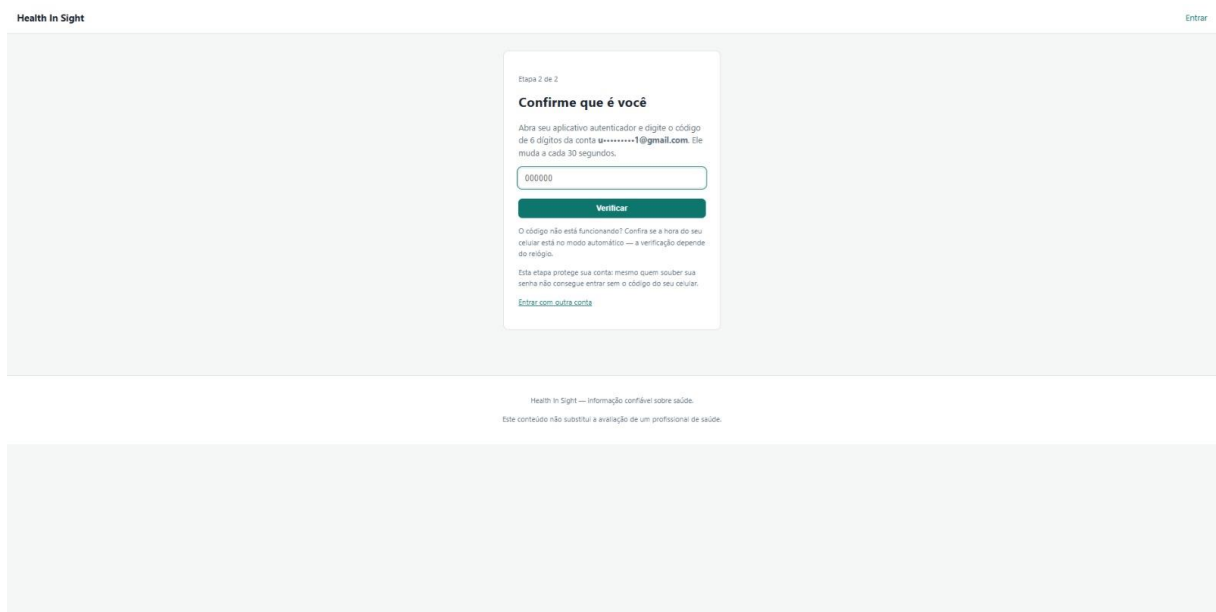
*Legenda: Formulário de criação de conta, coletando apenas e-mail, nome e senha; a tela lista as regras de senha e informa explicitamente que nenhum dado de saúde é coletado, antes de criar a conta, aparece um pop up, explicando sobre os dados, sendo necessário ler e concordar para continuar com a criação de uma conta.*

#### 4.2.3 TELA DE LOGIN



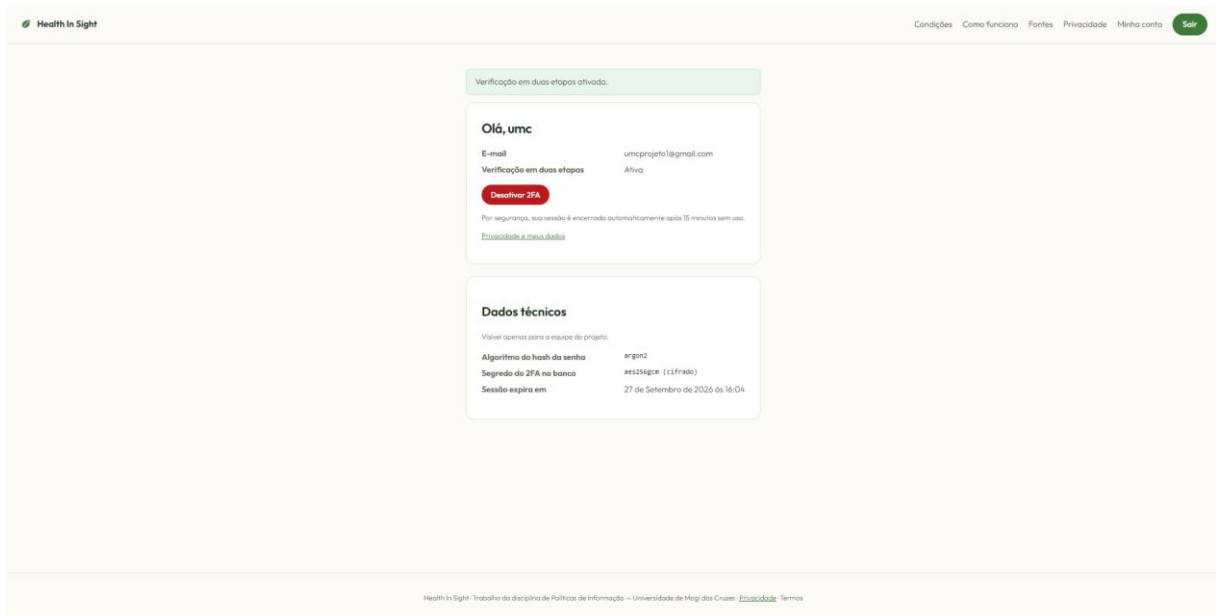
*Legenda: Etapa 1 de 2 do login: validação de e-mail e senha antes de liberar o desafio do segundo fator.*

#### 4.2.4 TELA DA AUTENTICAÇÃO



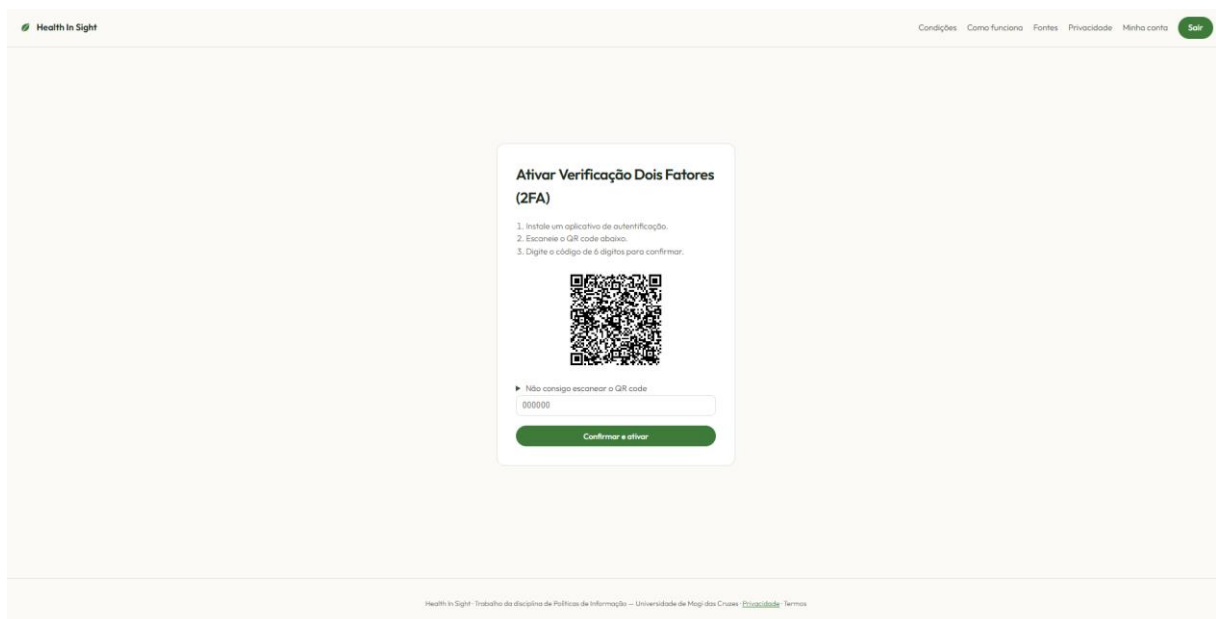
*Legenda: Etapa 2 de 2 do login: desafio do código TOTP de 6 dígitos, com o e-mail da conta parcialmente mascarado na tela.*

#### 4.2.5 TELA DO ADMINISTRADOR



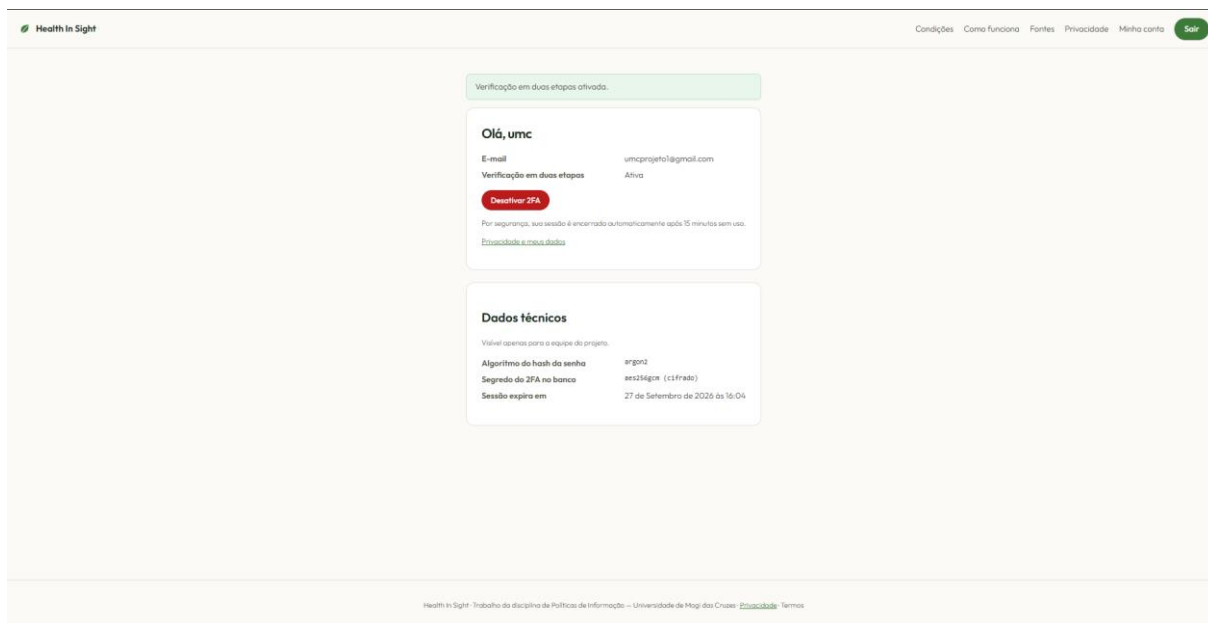
*Legenda: Painel do administrador, com o status da verificação em duas etapas e um bloco de dados técnicos (algoritmo de hash da senha e horário de expiração da sessão), visível apenas para a equipe do projeto.*

#### 4.2.6 TELA DE ATIVAÇÃO DO 2FA



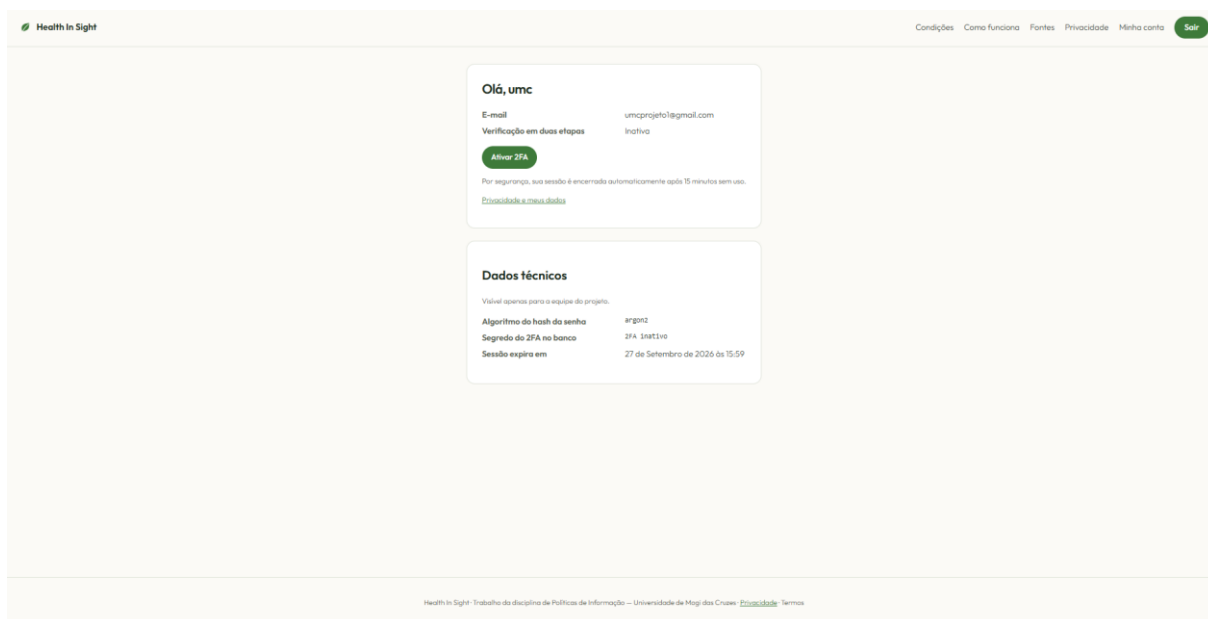
*Legenda: Ativação do 2FA: exibição do QR Code a ser escaneado pelo aplicativo autenticador e campo para confirmar o primeiro código gerado.*

#### 4.2.7 TELA COM A REATIVAÇÃO DO 2FA



*Legenda: Confirmação de reativação do 2FA ("Verificação em duas etapas ativada."), com o painel já refletindo o novo status.*

#### 4.2.8 TELA COM A DESATIVAÇÃO DO 2FA



*Legenda: Confirmação de desativação do 2FA ("Verificação em duas etapas desativada."), com o painel voltando a oferecer a opção "Ativar 2FA".*

#### 4.2.9 TELA SOBRE DADOS E CONTAS

Tudo o que o Health In Sight guarda sobre a sua conta, conforme o Art. 18 da LGPD.

[Exportar em JSON](#)
[Revogar consentimento e excluir conta](#)

|                            |                       |
|----------------------------|-----------------------|
| Nome completo              | umc projeto admin     |
| E-mail                     | umcprojeto1@gmail.com |
| Cadastrado em              | 20/09/2026 20:19      |
| Última troca de senha      | 20/09/2026 20:19      |
| Verificação em duas etapas | ativa                 |

|                |                                                                                                       |
|----------------|-------------------------------------------------------------------------------------------------------|
| Senha          | Guardada apenas como hash Argon2id, que não permite recuperar a senha. Não é exportada por segurança. |
| Segredo do 2FA | Guardado cifrado com AES-256-GCM, Não é exportado por segurança.                                      |

|                       |                                                                                                       |
|-----------------------|-------------------------------------------------------------------------------------------------------|
| <b>Senha</b>          | Guardada apenas como hash-Argon2id, que não permite recuperar a senha. Não é exportada por segurança. |
| <b>Segredo do 2FA</b> | Guardado criptado com AES-256-GCM. Não é exportado por segurança.                                     |

| Finalidade                       | Valor | Assinatura       | Signtex |
|----------------------------------|-------|------------------|---------|
| Criação e transferência de conta | 10    | 30/09/2020 09:20 | Vigente |

### Accesos realizados

[illegible]

| Uitvoersland of oorsprong | Quantiteit | Endoorge IP | Revenegator |
|---------------------------|------------|-------------|-------------|
| Nederlands-Indië          |            |             |             |

| Event              | Date | Endings IP |
|--------------------|------|------------|
| Neuronal apoptosis |      |            |

*Legenda: Esta tela é referente ao usuário administrador do sistema, aparecendo as informações importantes como, credenciais, consentimentos, os registros de segurança, tentativas de acesso e recuperações de senha.*

#### 4.2.10 TELA DOS LOGS

Administração do Django

REM-VINDO(A), UMC. VER O SITE / ALTERAR SENHA / ENCERRAR SESSÃO

Início » auditoria » Eventos de autenticação

Selecione evento de autenticação para visualizar

Q. Pesquisar

2026 20 de Setembro 22 de Setembro 23 de Setembro 25 de Setembro 27 de Setembro

| REGISTRADO EM                   | EVENTO                         | USUARIO                  | IDENTIFICADOR SELLADO | ENDERECO DE REDE |
|---------------------------------|--------------------------------|--------------------------|-----------------------|------------------|
| 27 de Setembro de 2026 às 15:56 | Login concluído                | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 27 de Setembro de 2026 às 15:49 | Segundo fator ativado          | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 27 de Setembro de 2026 às 15:42 | Login concluído                | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 27 de Setembro de 2026 às 15:37 | Sessão encerrada               | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 27 de Setembro de 2026 às 15:34 | Login concluído                | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 10:01 | Sessão encerrada               | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 09:59 | Login concluído                | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 09:58 | Sessão encerrada               | umcprojeto123@proton.me  | 23                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 09:58 | Login concluído                | umcprojeto123@proton.me  | 23                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 09:58 | Conta criada                   | umcprojeto123@proton.me  | 23                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 09:07 | Login concluído                | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:49 | Login concluído                | begio6814@pumpoly.com    | 21                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:49 | Sessão encerrada               | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:45 | Login concluído                | umcprojeto1@gmail.com    | 20                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:44 | Sessão encerrada               | cassianoascaca@gmail.com | 17                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:44 | Segundo fator ativado          | cassianoascaca@gmail.com | 17                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:43 | Login concluído                | cassianoascaca@gmail.com | 17                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:43 | Senha inválida                 | begio6814@pumpoly.com    | 21                    | 127.0.0.1        |
| 25 de Setembro de 2026 às 08:43 | Conta bloqueada por tentativas | begio6814@pumpoly.com    | 21                    | 127.0.0.1        |

FILTRO

Mostrar contagem

Por evento

- Todos
- Login concluído
- Senha inválida
- Sessão encerrada
- Segundo fator validado
- Código do segundo fator inválido
- Segundo fator ativado
- Segundo fator desativado
- Conta bloqueada por tentativas
- Conta criada
- Conta excluída pelo titular

Por registrado em

Qualquer data

Hoje

Últimos 7 dias

Este mês

Este ano

*Legenda: Esta tela se refere aos logs, onde estão registrados todos os acessos no site, como é possível visualizar na imagem a cima.*

## 5 TESTES, VALIDAÇÃO E RESULTADOS

### 5.1 ESTRATÉGIAS DE TESTES

Os testes automatizados foram escritos com o framework de testes do Django (TestCase), executados contra um banco de dados em memória isolado do ambiente de produção. Cada teste é nomeado com o número do item do check-list ao qual se refere, o que permite rastrear diretamente a cobertura de cada requisito.

A suíte cobre os cinco blocos entregues: autenticação e gestão de credenciais, recuperação de senha, criptografia e comunicação segura, conformidade com a LGPD e auditoria e logs — incluindo um teste dedicado que garante que nenhum evento de auditoria é perdido silenciosamente durante o fluxo de exclusão de conta.

Como o edital exige que os requisitos sejam testados e demonstrados obrigatoriamente através do front-end, os testes automatizados foram complementados por testes manuais na aplicação em produção, documentados pelos prints reunidos na seção 4.2, e pela execução do comando `verificar_logs`, que confirma publicamente a integridade da cadeia de hash da trilha de auditoria.

### 5.2 RESULTADOS OBTIDOS

[Antes de entregar: rodar ``python manage.py test``, conferir quantos testes passaram e substituir os colchetes abaixo pelo número real.] Na versão entregue, a suíte de testes automatizados soma [N] testes, todos aprovados, cobrindo os cinco blocos de requisitos do check-list.

Durante a validação manual do bloqueio por força bruta, a equipe identificou que o django-axes estava, por padrão, bloqueando apenas por endereço IP, e não por conta — porque o nome do campo de usuário do formulário de login não coincidia com o esperado pela biblioteca. A correção (parâmetro `AXES_USERNAME_FORM_FIELD`) foi validada com uma consulta direta ao banco de dados, comparando o campo `username` do registro de bloqueio antes e depois do ajuste — episódio documentado aqui como evidência de que os testes de segurança não se limitaram a verificar se a funcionalidade existia, mas se ela se comportava como especificado.

## 6 CONSIDERAÇÕES FINAIS

### 6.1 CONCLUSÃO

O projeto Health In Sight entregou, até o momento, os cinco blocos de requisitos de segurança e conformidade previstos no check-list da disciplina: autenticação e gestão de credenciais, recuperação de senha, criptografia e comunicação segura, conformidade com a LGPD e auditoria e logs — todos implementados, testados automaticamente e validados manualmente em produção.

O principal aprendizado da equipe foi que segurança da informação não se resume à escolha do algoritmo certo, mas à forma como os componentes se comportam em conjunto: o caso do bloqueio por força bruta, que funcionava sem cumprir a especificação até um teste manual revelar a falha, ilustra por que a validação funcional é indispensável mesmo quando a biblioteca usada é confiável.

Como próximos passos, o catálogo de conteúdos de saúde, o prazo de retenção dos registros de auditoria e a produção dos artefatos científicos finais (resumo e pôster) permanecem como itens em aberto para a etapa seguinte do projeto.

### REFERÊNCIAS

ALWEN, J.; BLOCKI, J.; HARSHA, B. et al. RFC 9106: Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications. Fremont: IETF, 2021.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 2018.

DJANGO SOFTWARE FOUNDATION. Django Documentation. Disponível em: <https://docs.djangoproject.com/>. Acesso em: 2026.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva: ISO, 2022.

M'RAIHI, D.; MACHANI, S.; PEI, M.; RYDELL, J. RFC 6238: TOTP: Time-Based One-Time Password Algorithm. Fremont: IETF, 2011.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management. Gaithersburg: NIST, 2017.

OWASP FOUNDATION. Password Storage Cheat Sheet. OWASP Cheat Sheet Series, 2023.

Disponível em:

[https://cheatsheetseries.owasp.org/cheatsheets/Password\\_Storage\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html).

SCHNEIER, B.; KELSEY, J. Secure audit logs to support computer forensics. ACM Transactions on Information and System Security, v. 2, n. 2, p. 159–176, 1999.

WORLD HEALTH ORGANIZATION. Infodemic. Geneva: WHO, [s.d.]. Disponível em:

<https://www.who.int/health-topics/infodemic>.